

Salesforce Security Questionnaire Draft (Mapped)

Prepared date: February 14, 2026

1. Application Overview

Q: Describe application architecture. A: AppGrid runs as a Salesforce managed package using an LWC host that renders a React frontend. Business/data operations execute through Apex. Slack integration is handled server-side via Apex callouts.

Evidence: - appExchange docs/AppExchange_Architecture_Diagram.md - AgGrid2025GA/force-app/main/default/lwc/appGridLwc/appGridLwc.js - AgGrid2025GA/force-app/main/default/classes/AppGridController.cls

2. External Hosting and Third-Party Services

Q: Does the app load externally hosted code? A: Yes. Static React assets are loaded from <https://www.appgridlwc.com> (Cloudflare-backed delivery). Evidence: -

AgGrid2025GA/force-app/main/default/lwc/appGridLwc/appGridLwc.js:107 - AgGrid2025GA/force-app/main/default/remoteSiteSettings/AppGrid_Cloudflare.remoteSite-meta.xml - AgGrid2025GA/force-app/main/default/cspTrustedSites/AppGrid_Cloudflare.cspTrustedSite-meta.xml

Q: Does Cloudflare store Salesforce customer business data? A: Intended model is static asset delivery only; Salesforce data processing remains in LWC/Apex/SObjects. Action to finalize before submission: - Add explicit Cloudflare privacy statement and change-control note.

Q: What external APIs are used? A: Slack Web API over HTTPS/TLS through Apex callouts. Evidence: - AgGrid2025GA/force-app/main/default/classes/AgSlackService.cls - AgGrid2025GA/force-app/main/default/remoteSiteSettings/Slack_API.remoteSite-meta.xml

3. Authentication and Authorization

Q: How are record-level permissions enforced? A: Core Apex controllers/services run with sharing with user-mode query/DML patterns. Evidence: - AgGrid2025GA/force-app/main/default/classes/AppGridController.cls:240 - AgGrid2025GA/force-app/main/default/classes/AppGridController.cls (WITH USER_MODE, AccessLevel.USER_MODE usage)

Q: How is Slack authentication handled? A: OAuth flow via Slack authorization endpoint, callback processing in Salesforce, token state checks, and revoke flow. Evidence: - AgGrid2025GA/force-app/main/default/classes/AgSlackUserOAuthController.cls - AgGrid2025GA/docs/SLACK_AUTHENTICATION_FLOW.md

Q: Are OAuth scopes least privilege? A: Scope list is implemented but requires explicit scope-to-feature minimization narrative for submission. Action to finalize before submission: - Add scope justification table and remove non-essential scopes.

4. Sensitive Data and Token Management

Q: How are secrets/tokens stored? A: Slack token fields use EncryptedText in Salesforce. Evidence: - AgGrid2025GA/force-app/main/default/objects/Ag_SlackUser_Token__c/fields/AccessToken__c.field-meta.xml - AgGrid2025GA/force-app/main/default/objects/Ag_Slack_Config__c/fields/Bot_Token__c.field-meta.xml

Q: Are secrets exposed to clients? A: Needs tightening. Current review identified token-return paths in OAuth controller responses that should be removed or strongly justified. Action to finalize before submission: - Remove/limit client-facing token return payloads.

5. Data Handling and Privacy

Q: What Salesforce data is sent externally? A: Slack feature payloads are sent when enabled/triggered. Field-level payload definition requires explicit final documentation. Action to finalize before submission: - Add a field-level payload matrix by Slack operation and PII boundary statement.

Q: Is user/admin consent clear? A: Integration includes enable flags and OAuth connect flow; admin-consent UX narrative should be explicit in submission docs. Evidence: - AgGrid2025GA/force-app/main/default/objects/Ag_Slack_Object_Config__c/fields/Enabled__c.field-meta.xml

6. Runtime Security Controls

Q: How is iframe messaging protected? A: LWC validates message source window and origin allowlist before processing requests. Evidence: - AgGrid2025GA/force-app/main/default/lwc/appGridLwc/appGridLwc.js:348 - AgGrid2025GA/force-app/main/default/lwc/appGridLwc/appGridLwc.js:355

Q: How does app fail when external auth is missing/invalid? A: Controlled error paths exist for missing token, unauthorized token, and missing scope. Evidence: - AgGrid2025GA/force-app/main/default/classes/AgSlackService.cls:789 - AgGrid2025GA/force-app/main/default/classes/AgSlackService.cls:840 - AgGrid2025GA/force-app/main/default/classes/AgSlackService.cls:878

7. Secure Defaults

Q: Are external integrations secure by default? A: Partially. Some Slack feature toggles default disabled (Enabled__c=false), but Ag_Slack_Config__c.Is_Active__c default is true and should be reviewed for strict default-off posture. Evidence: - AgGrid2025GA/force-app/main/default/objects/Ag_Slack_Object_Config__c/fields/Enabled__c.field-meta.xml
- AgGrid2025GA/force-app/main/default/objects/Ag_Slack_Config__c/fields/Is_Active__c.field-meta.xml

8. Scanner and Testing Artifacts

Q: Current static analysis status? A: No Sev1/Sev2 findings; remaining findings are Severity 3 with documented rationale. Evidence: - AgGrid2025GA/CodeAnalyzerReport.html - AgGrid2025GA/react/documentation/CODE_ANALYZER_SECURITY_JUSTIFICATION.md

9. Documentation to Attach

- appExchange docs/
AppExchange_Security_Review_Submission_Package.md
- appExchange docs/AppExchange_Architecture_Diagram.md
- appExchange docs/Salesforce_Security_Questionnaire_Draft.md
- AgGrid2025GA/CodeAnalyzerReport.html
- AgGrid2025GA/react/documentation/
CODE_ANALYZER_SECURITY_JUSTIFICATION.md

10. Final Pre-Submission Closures

1. Publish Cloudflare addendum (CDN-only role, integrity controls, change/incident process).
2. Publish Slack addendum (scope minimization table, field-level payload matrix, admin controls).
3. Eliminate or justify any client-facing token return paths.
4. Align secure-default statements with metadata defaults and operational behavior.